

Multi-Factor Authentication (MFA) e Acesso Condicional

Autenticação forte, fatores clássicos, tecnologias resistentes a phishing e arquiteturas de acesso condicional baseado em risco.

VISÃO GERAL

O que é Autenticação Multifator?

O MFA combina dois ou mais fatores independentes de verificação de identidade. O objetivo é garantir que o comprometimento de um único fator não seja suficiente para conceder acesso indevido — elevando significativamente a barreira para o atacante.

- ✔ Proteção mesmo se a senha for vazada
- ✔ Impedimento de ataques automatizados em massa

Algo que você sabe

Senhas, PINs e perguntas secretas.

Algo que você tem

Tokens, smartphones e chaves FIDO2.

Algo que você é

Biometria (impressão digital ou facial) e comportamento.

FATOR 1

Fator de Conhecimento

Senhas, PINs e respostas a perguntas de segurança são o fator mais difundido — e o mais vulnerável. Nunca deve ser usado isoladamente em ambientes de alto risco.

Phishing

Captura de credenciais via páginas falsas idênticas às originais.

Credential Stuffing

Reuso de senhas vazadas em outros serviços por robôs automatizados.

Engenharia Social

Manipulação psicológica para revelação direta de respostas secretas.

FATOR 2

Fator de Posse

Tokens físicos ou virtuais que o aluno possui. A segurança depende da exclusividade do dispositivo — se o token não pode ser clonado, o acesso é protegido mesmo com a senha comprometida.

Apps Autenticadores

Google e Microsoft Authenticator geram códigos TOTP offline no celular.

Chaves FIDO2

YubiKey e similares — autenticação por toque físico, altamente resistente.

Smart Cards

Cartões com chip embarcado usados em órgãos corporativos e governamentais.

Tokens HOTP/TOTP

RFC 4226 e 6238 — algoritmos padrão para geração de senhas de uso único.

FATOR 3

Fator de Inerência (Biometria)

Impressão digital, reconhecimento facial, íris e voz oferecem alta conveniência, mas exigem atenção a pontos críticos de segurança e conformidade jurídica.

Liveness Detection

Mitiga ataques com fotos, vídeos ou máscaras 3D verificando sinais de vida.

Irrevogabilidade

Uma impressão digital comprometida não pode ser trocada como uma senha comum.

Privacidade (LGPD)

Dados biométricos são altamente sensíveis e rigorosamente regulados por lei.

TECNOLOGIA MODERNA

FIDO2 e WebAuthn

Padrão W3C para autenticação sem senha baseada em chaves públicas. O autenticador gera um par de chaves único por serviço — o segredo nunca sai do dispositivo.



Resistente a phishing por design!

Chave Pública no Servidor

Apenas a chave pública é registrada — inútil para o atacante sem o dispositivo.

Chave Privada no Dispositivo

Nunca transmitida, protegida por PIN, biometria ou toque físico.

AMEAÇA

MFA Fatigue / Prompt Bombing

Após obter a senha, o adversário dispara dezenas de notificações MFA até que o aluno, exausto ou confuso, aprove uma por engano.

Como mitigar

Uso de Number Matching e políticas restritivas de acesso condicional.

Number Matching

O aluno digita no app o número exibido na tela de login.

Contexto Geográfico

Alertas mostram localização e dispositivo da tentativa de acesso.

Acesso Condicional Baseado em Risco

Avalia sinais de risco em tempo real antes de conceder ou bloquear o acesso. A decisão é dinâmica: o mesmo aluno pode ter experiências diferentes dependendo do contexto da tentativa.

Sinais comuns: Localização geográfica incomum, dispositivo não gerenciado, horário atípico e velocidade de deslocamento impossível.



1. Registro e Alerta
Logs e notificações de segurança.



2. Decisão Dinâmica
Conceder, MFA ou bloquear.



3. Avaliar Sinais
Local, dispositivo, comportamento.



4. Tentativa de Login
Detecção de acesso inicial.

PRÁTICA

Desafio Prático com Entrega no GitHub



1. Acesse o repositório

github.com/profclovesrocha/posIAM



2. Implemente a solução

Siga as instruções do desafio da Aula 04.



3. Submeta no GitHub

Entrega via pull request no repositório da disciplina.

 FACULDADE ESUDA · PÓS-GRADUAÇÃO

Encerramento & Contato

Trabalho acadêmico desenvolvido na Faculdade Esuda com foco em segurança defensiva e arquiteturas de identidade corporativa.

ALUNO

Fernando Luiz Casstro dos Santos Filho

CONEXÃO PROFISSIONAL

[linkedin.com/in/fernando-filho-18771520b](https://www.linkedin.com/in/fernando-filho-18771520b)